

RAPPORT DE TEST D'INTRUSION

Basic Pentesting

Évaluation de sécurité d'un hôte Linux et de ses services exposés

Paramètre	Valeur
Environnement	TryHackMe - Basic Pentesting (laboratoire autorisé)
Cible observée	10.128.x.x / 10.129.x.x - adresse dynamique du laboratoire
Référentiel	Penetration Testing Execution Standard (PTES)
Date du test	19 juin 2026
Testeur	Dimitri Marquet - dimisan221
Version	2.0 - harmonisation graphique et structurelle

CLASSIFICATION Version portfolio public. Les secrets du laboratoire sont masqués et la cible est anonymisée.

Rapport établi à partir des constats et preuves consignés pendant le laboratoire.

Contrôle du document

Historique des versions

Version	Date	Auteur	Description
1.0	19/06/2026	dimisan221	Première rédaction du rapport Basic Pentesting.
2.0	28/08/2026	dimisan221	Reprise de la structure et de la présentation du rapport Beach Bar.

Destinataires

Destinataire principal : évaluateur pédagogique, recruteur ou lecteur du portfolio. Toute réutilisation des commandes doit rester limitée à un système explicitement autorisé.

Hypothèses et informations manquantes

Le laboratoire fournit l'autorisation implicite liée au cadre TryHackMe. Il ne fournit pas de lettre d'autorisation, de fenêtre de test, de contacts d'urgence, de liste d'exclusions ni de critères d'arrêt. Dans un engagement réel, ces éléments doivent être définis avant toute intervention.

PORTÉE DU RAPPORT Les conclusions reposent exclusivement sur les actions documentées. Aucun déni de service, test de persistance, mouvement latéral ou contre-test après correction n'a été réalisé.

Table des matières

- 1. Synthèse exécutive**
- 2. Contexte, périmètre et règles d'engagement**
- 3. Méthodologie PTES**
- 4. Résultats techniques et chaîne d'attaque**
- 5. Fiches de vulnérabilités**
- 6. Plan de remédiation priorisé**
- 7. Conclusion**

Annexe A. Preuves et commandes techniques

Annexe B. Références

1. Synthèse exécutive

L'évaluation de la machine TryHackMe Basic Pentesting a mis en évidence une chaîne d'attaque permettant à un attaquant distant de compromettre successivement deux comptes utilisateurs. Le risque global est évalué comme élevé.

CONSTAT PRINCIPAL Un partage SMB anonyme divulgue des comptes valides. Un mot de passe SSH faible permet l'accès au compte jan, puis des permissions excessives sur la clé privée de kay et une passphrase faible permettent de compromettre le second compte. Aucun accès root n'a été obtenu.

Vue d'ensemble des risques

ID	Constat	Sévérité	Effet principal
BP-01	Mot de passe SSH faible - compte jan	Élevée	Accès distant non autorisé
BP-02	Clé SSH privée de kay lisible par tous	Élevée	Divulgateur d'un secret d'authentification
BP-03	Passphrase de clé SSH crackable	Élevée	Compromission du compte kay
BP-04	Informations divulguées via SMB anonyme	Moyenne	Découverte de comptes valides

Impact métier et technique

- Confidentialité : lecture de données accessibles aux comptes jan et kay, dont un fichier sensible.
- Intégrité : possibilité de modifier les fichiers appartenant aux comptes compromis.
- Disponibilité : impact limité aux droits des comptes compromis ; aucun contrôle administrateur démontré.
- Traçabilité : les attaques par dictionnaire et l'usage de secrets faibles compliquent l'attribution fiable des accès.

2. Contexte, périmètre et règles d'engagement

2.1 Objectif

L'objectif était d'identifier les services exposés, d'obtenir un accès initial au système, de compromettre un second compte utilisateur et de documenter la chaîne selon le référentiel PTES.

2.2 Périmètre observé

Élément	Valeur
Hôte	10.128.x.x / 10.129.x.x (adresse dynamique anonymisée)
Services	TCP/22 SSH ; TCP/80 HTTP ; TCP/139 et 445 SMB ; TCP/8009 AJP13 ; TCP/8080 HTTP-Proxy
Système	Ubuntu 20.04.6 LTS - noyau Linux 5.15.0
Comptes concernés	jan et kay
Type de test	Boîte noire dans un laboratoire isolé

2.3 Règles d'engagement

Le caractère autorisé du laboratoire TryHackMe est établi par le contexte. Pour un engagement réel, il serait nécessaire de valider par écrit :

- le propriétaire légal des actifs et l'autorisation du test ;
- les adresses, applications et comptes inclus ou exclus ;
- les horaires, contacts d'urgence et procédures d'arrêt ;
- les techniques autorisées, limites de charge et règles de conservation des preuves.

2.4 Limites

Aucune élévation jusqu'au compte root n'a été obtenue. Le test ne démontre donc pas une compromission complète de l'hôte. L'absence de constat sur un composant non testé ne signifie pas absence de vulnérabilité.

3. Méthodologie PTES

Le rapport suit les sept phases du Penetration Testing Execution Standard. La profondeur de chaque phase est adaptée au contexte pédagogique et aux preuves disponibles.

Phase	PTES	Application au test Basic Pentesting
1	Pré-engagement	Périmètre du laboratoire et autorisation THM identifiés.
2	Collecte de renseignements	Nmap, Gobuster, smbclient et lecture des fichiers exposés.
3	Modélisation des menaces	Priorisation de SSH, SMB et des comptes jan/kay.
4	Analyse des vulnérabilités	Validation du mot de passe faible, des permissions SSH et de la passphrase.
5	Exploitation	Attaque par dictionnaire puis compromission successive de jan et kay.
6	Post-exploitation	Lecture d'une donnée sensible sous kay, sans privilèges root.
7	Rapport	Qualification des risques, preuves et recommandations.

3.1 Échelle de sévérité

Niveau	Interprétation
Critique	Compromission complète ou impact majeur immédiat.
Élevée	Accès non autorisé ou exposition d'un secret sensible avec impact important.
Moyenne	Faiblesse exploitable qui facilite une étape complémentaire.

Niveau	Interprétation
Faible	Impact limité ou conditions d'exploitation contraignantes.

4. Résultats techniques et chaîne d'attaque

4.1 Reconnaissance réseau

Un scan TCP Connect, sans phase de découverte d'hôte, a cartographié les services exposés. L'adresse dynamique est remplacée par <IP_CIBLE>.

```
nmap -sT -Pn -T4 <IP_CIBLE>
```

Port	État	Service	Observation
22/tcp	Ouvert	SSH	Vecteur d'accès initial
80/tcp	Ouvert	HTTP (Apache)	Site web en maintenance
139/tcp	Ouvert	NetBIOS-SSN	Transport SMB historique
445/tcp	Ouvert	Microsoft-DS	Service SMB
8009/tcp	Ouvert	AJP13	Connecteur Apache Tomcat
8080/tcp	Ouvert	HTTP-Proxy	Interface Tomcat

4.2 Énumération web

```
gobuster dir -u http://<IP_CIBLE>:80 -w /usr/share/wordlists/dirb/common.txt
```

Le répertoire /development/ a été découvert avec un code HTTP 301. Son index Apache exposait deux fichiers :

- dev.txt : mention d'Apache Struts 2.5.12, de SMB et de messages signés K et J ;
- j.txt : indication que l'utilisateur J emploie un mot de passe faible.

4.3 Énumération SMB et accès initial

Le partage SMB Anonymous était accessible sans authentification. Le fichier staff.txt révélait deux comptes valides : jan et kay.

```
smbclient //<IP_CIBLE>/Anonymous -N
```

4.4 Compromission du compte jan

L'information issue de j.txt et l'identifiant découvert via SMB ont permis de cibler une attaque par dictionnaire contre SSH. Le secret réel reste volontairement masqué dans cette version publique.

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://<IP_CIBLE> -t 4
ssh jan@<IP_CIBLE> # mot de passe masqué : a*****
```

RÉSULTAT Un accès SSH interactif a été obtenu sous le compte jan. Ce compte ne disposait pas des privilèges administrateur.

4.5 Découverte de la clé privée de kay

Depuis la session jan, le fichier /home/kay/.ssh/id_rsa était lisible en raison de permissions 644. Une clé privée ne doit normalement être accessible qu'à son propriétaire.

```
ls -l /home/kay/.ssh/id_rsa
cat /home/kay/.ssh/id_rsa
chmod 600 /tmp/kay_id_rsa
```

4.6 Compromission du compte kay

La clé privée était protégée par une passphrase. Une attaque hors ligne avec John the Ripper et la liste rockyou.txt a permis de retrouver cette phrase secrète en moins d'une minute.

```
ssh2john /tmp/kay_id_rsa > /tmp/kay_hash.txt
john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
ssh -i /tmp/kay_id_rsa kay@<IP_CIBLE> # passphrase masquée : b*****
```

RÉSULTAT Le compte kay a été compromis et une donnée sensible a été consultée. Aucun accès root n'a été obtenu ; la chaîne s'arrête donc au niveau utilisateur.

4.7 Chaîne d'attaque validée

1. Découverte des services SSH, HTTP et SMB.
2. Accès anonyme au partage SMB et découverte des comptes jan et kay.
3. Attaque par dictionnaire contre le compte SSH jan.
4. Lecture de la clé privée de kay depuis la session jan.
5. Découverte hors ligne de la passphrase de la clé.
6. Authentification sous kay et accès à une donnée sensible, sans privilèges root.

POINT DE RUPTURE PRIORITAIRE Corriger les permissions de la clé privée ou empêcher l'accès initial SSH suffit à interrompre la chaîne observée. L'application conjointe des mesures apporte une défense en profondeur.

5. Fiches de vulnérabilités

BP-01 - Mot de passe SSH faible - utilisateur jan

SÉVÉRITÉ ÉLEVÉE CWE-521 - Weak Password Requirements. CVSS v3 estimé : 8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N).

Description

Le compte jan utilise un mot de passe extrêmement faible, présent dans des listes publiques courantes. Un attaquant distant peut obtenir un accès SSH à l'aide d'un outil automatisé d'attaque par dictionnaire.

Preuve et reproductibilité

L'attaque Hydra avec rockyou.txt a retrouvé le mot de passe. Le secret est masqué sous la forme a***** dans cette version publique.

Impact

La faiblesse fournit un accès distant authentifié au compte jan. Elle devient particulièrement grave lorsqu'elle est combinée aux permissions excessives de la clé privée de kay.

Recommandations

- Imposer des mots de passe longs, uniques et absents des listes de secrets compromis.
- Privilégier l'authentification SSH par clé et désactiver l'authentification par mot de passe lorsque cela est possible.
- Limiter les tentatives et surveiller les échecs d'authentification, par exemple avec Fail2ban.
- Mettre en place une authentification multifacteur pour les accès distants sensibles.

BP-02 - Clé SSH privée de kay lisible par tous

SÉVÉRITÉ ÉLEVÉE CWE-732 - Incorrect Permission Assignment for Critical Resource. Permissions observées : -rw-r--r-- (644).

Description

La clé privée /home/kay/.ssh/id_rsa était lisible par tous les utilisateurs locaux. Tout compte déjà compromis pouvait donc copier ce secret d'authentification et tenter de l'utiliser.

Impact

La divulgation de la clé privée supprime une barrière essentielle entre les comptes jan et kay. La protection restante dépend uniquement de la robustesse de la passphrase.

Recommandations

- Appliquer immédiatement `chmod 600 /home/kay/.ssh/id_rsa` et `chmod 700 /home/kay/.ssh`.
- Révoquer et renouveler la clé, car elle doit être considérée comme compromise après exposition.
- Automatiser l'audit des permissions des clés privées et des fichiers sensibles.
- Appliquer le principe du moindre privilège aux répertoires personnels.

Preuve technique

```
-rw-r--r-- 1 kay kay ... /home/kay/.ssh/id_rsa
chmod 600 /home/kay/.ssh/id_rsa
```


BP-03 - Passphrase de clé SSH crackable

SÉVÉRITÉ ÉLEVÉE CWE-521 - Weak Password Requirements. Découverte hors ligne en moins d'une minute avec rockyou.txt.

La passphrase protégeant la clé de kay était trop faible pour résister à une attaque par dictionnaire. Une fois la clé copiée, l'attaque pouvait être réalisée hors ligne sans limitation de tentatives.

- Utiliser une phrase secrète longue, unique et générée aléatoirement.
- Stocker les passphrases dans un gestionnaire de mots de passe.
- Renouveler la paire de clés après toute suspicion d'exposition.

BP-04 - Divulgateion d'informations via SMB anonyme

SÉVÉRITÉ MOYENNE CWE-200 - Exposure of Sensitive Information to an Unauthorized Actor. Partage Anonymous accessible sans authentification.

Le partage SMB exposait staff.txt, qui révélait les noms d'utilisateurs jan et kay. Cette information a directement facilité le ciblage de l'attaque SSH.

- Désactiver les partages anonymes lorsqu'ils ne sont pas nécessaires.
- Ne pas publier d'informations sur les comptes dans des partages non authentifiés.
- Restreindre SMB aux utilisateurs nécessaires et segmenter l'accès réseau.

6. Plan de remédiation priorisé

Priorité	Délai	Action	Résultat attendu
P0	Immédiat	Corriger les permissions de la clé privée et renouveler la paire de clés de kay.	Blocage du pivot vers kay.
P0	Immédiat	Changer le mot de passe de jan et invalider toutes les sessions actives.	Suppression de l'accès connu.
P1	7 jours	Désactiver l'authentification SSH par mot de passe lorsque possible.	Réduction des attaques par dictionnaire.
P1	7 jours	Désactiver ou sécuriser le partage SMB anonyme.	Suppression de la fuite de comptes.
P1	14 jours	Déployer limitation, supervision et alertes sur les échecs SSH.	Détection des tentatives automatisées.
P2	30 jours	Automatiser l'audit des permissions et des secrets faibles.	Prévention durable des régressions.
P2	Après correction	Réaliser un contre-test ciblé de la chaîne complète.	Validation de l'efficacité des correctifs.

6.1 Critères de contre-test

- Le partage SMB n'est plus accessible anonymement et ne divulgue aucun compte.
- Une attaque par dictionnaire contrôlée ne permet plus d'authentifier jan.
- La clé privée de kay n'est lisible que par son propriétaire et l'ancienne clé est révoquée.
- La nouvelle passphrase résiste aux listes de mots de passe courantes.
- Aucun autre fichier sensible n'est accessible depuis un compte utilisateur distinct.

7. Conclusion

Le test démontre qu'une combinaison de faiblesses simples peut mener à la compromission successive de plusieurs comptes. La fuite d'identifiants via SMB rend l'attaque plus ciblée ; le mot de passe faible de jan fournit l'accès initial ; les permissions incorrectes et la passphrase faible de la clé de kay permettent le pivot vers un second compte.

Le scénario documenté s'arrête au compte kay : aucun accès administrateur root n'a été obtenu. Le risque reste néanmoins élevé, car des données sensibles ont été consultées et la séparation entre comptes utilisateurs a été contournée.

RISQUE RÉSIDUEL Le risque reste élevé tant que les secrets faibles, les permissions excessives et l'accès SMB anonyme ne sont pas corrigés puis contre-testés.

La priorité doit être donnée à la rotation des secrets et à la correction des permissions, puis au durcissement de SSH, de SMB et de la surveillance. Un contre-test ciblé est recommandé après application des correctifs.

Annexe A - Preuves et commandes techniques

Les commandes suivantes résument les validations effectuées dans le laboratoire autorisé. Les adresses et secrets sont anonymisés.

A.1 Reconnaissance

```
nmap -sT -Pn -T4 <IP_CIBLE>
gobuster dir -u http://<IP_CIBLE>:80 -w /usr/share/wordlists/dirb/common.txt
smbclient //<IP_CIBLE>/Anonymous -N
```

A.2 Exploitation contrôlée

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://<IP_CIBLE> -t 4
cat /home/kay/.ssh/id_rsa
ssh2john /tmp/kay_id_rsa > /tmp/kay_hash.txt
john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
ssh -i /tmp/kay_id_rsa kay@<IP_CIBLE>
```

PRÉCAUTION Ces commandes proviennent d'un laboratoire pédagogique. Elles ne doivent jamais être utilisées contre un système sans autorisation explicite.

Annexe B - Références

- Penetration Testing Execution Standard (PTES) - <https://www.pentest-standard.org/>
- MITRE CWE-200 - Exposure of Sensitive Information to an Unauthorized Actor.
- MITRE CWE-521 - Weak Password Requirements.
- MITRE CWE-732 - Incorrect Permission Assignment for Critical Resource.
- FIRST - Common Vulnerability Scoring System v3.1 Specification.